Universidad de Extremadura

Escuela Politécnica

Ingeniería Informática en Ingeniería del Software

Trabajo Fin de Grado

Desarrollo de una herramienta para la automatización de tareas de reconocimiento en auditorías de seguridad

David Gordillo Burrero

Convocatoria, 2025

Universidad de Extremadura

Escuela Politécnica

Ingeniería Informática en Ingeniería del Software

Trabajo Fin de Grado

Desarrollo de una herramienta para la automatización de tareas de reconocimiento en auditorías de seguridad

Autor: David Gordillo Burrero

Tutor: Tutor

Resumen

En el presente trabajo se ha desarrollado una herramienta orientada a la automatización de tareas fundamentales en auditorías de seguridad, con un enfoque específico en la fase de reconocimiento. Esta etapa, crítica en cualquier proceso de pentesting, abarca actividades como la recolección de información pasiva y activa, el escaneo de puertos y servicios, la enumeración de subdominios y tecnologías, así como la identificación preliminar de posibles vulnerabilidades.

La solución propuesta integra múltiples utilidades y técnicas ampliamente utilizadas en entornos profesionales de ciberseguridad (como Nmap, Feroxbuster, WhatWeb o WPScan), y se construye sobre una arquitectura modular y escalable que permite incorporar nuevas funcionalidades de forma sencilla en el futuro. A través de una interfaz web intuitiva, el usuario puede gestionar proyectos, ejecutar escaneos personalizados y consultar resultados de manera clara y estructurada.

Esta herramienta permite optimizar el flujo de trabajo durante las fases iniciales de una auditoría, automatizando tareas repetitivas, centralizando la información obtenida y reduciendo significativamente los tiempos de ejecución. Por otra parte, incorpora un sistema de inteligencia artificial basado en modelos generativos, que facilita la interacción con el contexto del escaneo para obtener recomendaciones específicas o definir próximos pasos según las debilidades detectadas. Además, genera automáticamente informes técnicos versionados, lo que simplifica la documentación del proceso y mejora su trazabilidad sin necesidad de intervención manual.

Palabras clave: Seguridad, Hacking Ético, Auditoría, Automatización, Herramienta.

Abstract

This project presents the development of a tool aimed at automating fundamental tasks in security audits, with a specific focus on the reconnaissance phase. This stage, which is critical in any penetration testing process, includes activities such as passive and active information gathering, port and service scanning, subdomain and technology enumeration, and the preliminary identification of potential vulnerabilities.

The proposed solution integrates several tools and techniques widely used in professional cybersecurity environments (such as Nmap, Feroxbuster, WhatWeb, or WPScan), and is built on a modular and scalable architecture that facilitates the future incorporation of new functionalities. Through an intuitive web interface, users can efficiently manage projects, execute customized scans, and review results in a clear and structured way.

The tool helps optimize workflow during the initial stages of a security audit by automating repetitive tasks, centralizing collected data, and significantly reducing execution time. Moreover, it includes an artificial intelligence system based on generative models, which allows users to interact with the scan context to receive specific recommendations or define next steps based on detected weaknesses. Additionally, it automatically generates versioned technical reports, streamlining the documentation process and improving traceability without requiring manual intervention.

Keywords: Security, Ethical Hacking, Auditing, Automation, Tool.

Índice general

1. Introducción **1**

1.1. Estructura del documento 3

2. Objetivos **5**

2.1. Subobjetivos específicos 6

3. Estado del Arte **8**

3.1. Evolución de las auditorías de seguridad 9

3.2. Herramientas de reconocimiento automatizado 10

3.2.1. ProjectDiscovery Cloud 11

3.2.2. Intruder.io 12

3.2.3. Detectify 14

3.3. Comparativa de las soluciones analizadas 15

4. Metodología **17**

4.1. Estudio de la fase de reconocimiento 18

4.1.1. Metodologías de referencia 18

4.1.2. Enfoque adoptado en este trabajo 19

4.2. Análisis y elección de herramientas 20

4.2.1. Criterios de selección 20

4.2.2. Comparativa de herramientas consideradas 22

5. Implementación y desarrollo **26**

6. Resultados **27**

7. Conclusiones y trabajos futuros **28**

Anexos **29**

A. Ejemplo de anexo **30**

A.1. Sección de anexo 30

Bibliografía **31**

Índice de tablas

3.1. Comparativa entre la herramienta desarrollada y soluciones similares. . . . 16

4.1. Comparativa de herramientas para escaneo de puertos y servicios. 23

4.2. Comparativa de herramientas para reconocimiento de registros DNS. . . . 24

Índice de figuras

Capítulo 1

Introducción

Contenidos

1.1. Estructura del documento 3

En el ámbito de la ciberseguridad, el reconocimiento constituye una de las fases más importantes dentro de una auditoría. Esta fase inicial tiene como objetivo recopilar la máxima cantidad de información posible sobre el objetivo a analizar [1]. A partir de estos datos, el auditor puede identificar servicios expuestos, tecnologías empleadas y potenciales vectores de ataque, sentando así las bases para etapas más avanzadas como la explotación o escalación de privilegios.

A pesar de su importancia, las tareas asociadas al reconocimiento suelen ser repetitivas, tediosas y propensas a errores si se realizan manualmente. Además, muchas de las herramientas empleadas requieren conocimientos técnicos, uso de línea de comandos y un esfuerzo considerable para gestionar los resultados obtenidos. Este escenario genera una necesidad clara de soluciones que permitan automatizar este proceso, reducir los tiempos de ejecución y facilitar la gestión de la información recopilada.

El presente Trabajo de Fin de Grado surge como respuesta a esta problemática. Se ha desarrollado una herramienta que automatiza las tareas fundamentales de reconocimiento en una auditoría de seguridad, integrando distintas utilidades en un único entorno con interfaz gráfica. Esta solución permite realizar desde escaneos de puertos y servicios hasta la enumeración de subdominios, identificación de vulnerabilidades web, detección de CMS y análisis de servicios como FTP o SSH. Además, la herramienta permite interactuar con un sistema de inteligencia artificial basado en modelos generativos, que facilita la interpretación de resultados y la propuesta de acciones posteriores.

Entre las funcionalidades añadidas destacan también la generación automática y versionada de informes, la configuración de escaneos exhaustivos, la personalización del entorno mediante proxies y un sistema de proyectos que organiza los análisis por objetivo.

La herramienta está diseñada con una arquitectura modular y escalable, lo que permite incorporar en un futuro nuevas funcionalidades de forma sencilla. Esto la convierte en una solución con capacidad para seguir evolucionando y ampliándose mediante la integración de nuevos módulos que permitan cubrir un mayor número de servicios y casos de uso.

Durante el desarrollo se han evaluado múltiples alternativas tecnológicas, priorizando aquellas que ofrecieran un equilibrio entre rendimiento, actualización activa, facilidad de integración y compatibilidad. Herramientas como Nmap, Subfinder, Nuclei, WPScan o Feroxbuster han sido seleccionadas tras un análisis comparativo, mientras que otras como Nikto, Gobuster o Paramiko fueron descartadas por distintos motivos técnicos.

El resultado es una herramienta funcional, útil y extensible, capaz de reducir significativamente el tiempo y la carga de trabajo durante la fase de reconocimiento, agilizando así el proceso de auditoría y mejorando la calidad del análisis desde las primeras etapas.

1.1. Estructura del documento

Este documento se encuentra estructurado en siete capítulos, además de las correspondientes referencias bibliográficas. A continuación, se describe brevemente el contenido de cada uno de ellos:

- El **Capítulo 2** recoge los objetivos que se pretenden alcanzar con el desarrollo de la herramienta propuesta.
- El **Capítulo 3** presenta el estado del arte, en el que se analizan las principales herramientas existentes en el ámbito del reconocimiento automatizado y se identifican sus principales limitaciones.
- El **Capítulo 4** describe la metodología seguida para el desarrollo de la herramienta, justificando la elección de cada tecnología empleada y explicando el flujo de trabajo que se implementa durante el proceso de reconocimiento.
- El **Capítulo 5** detalla el proceso de implementación de la herramienta, desde el diseño de su arquitectura hasta la integración de sus distintos módulos.

- El **Capítulo 6** recoge los resultados obtenidos a partir de las pruebas realizadas sobre distintos escenarios, evaluando la eficacia de la herramienta y el cumplimiento de los objetivos definidos.

- El **Capítulo 7** expone las conclusiones extraídas del trabajo, así como posibles líneas futuras de mejora y ampliación del sistema desarrollado.

- Finalmente, se incluyen las **referencias bibliográficas** consultadas a lo largo del proyecto.

Capítulo 2

Objetivos

Contenidos

2.1. Subobjetivos específicos **6**

El principal objetivo de este Trabajo de Fin de Grado consiste en desarrollar una herramienta que automatice las tareas asociadas a la fase de reconocimiento de una auditoría, facilitando y agilizando la recopilación de información sobre un objetivo. Con ello se pretende reducir significativamente el tiempo, la carga de trabajo y los recursos humanos necesarios para realizar dichas tareas de forma manual, al mismo tiempo que se proporciona una interfaz gráfica intuitiva, fácil de usar y con distintas opciones de configuración que la hagan accesible también a perfiles sin conocimientos técnicos avanzados.

2.1. Subobjetivos específicos

Como consecuencia de este objetivo principal, se identifican los siguientes subobjetivos específicos:

- Estudiar la metodología seguida en la fase de reconocimiento de una auditoría de seguridad.
- Analizar las distintas alternativas tecnológicas disponibles para cada tarea de reconocimiento, con el fin de seleccionar las opciones más adecuadas en términos de rendimiento, flexibilidad e integración.
- Desarrollar módulos individuales responsables de cada una de las tareas clave que componen la fase de reconocimiento.
- Orquestar las herramientas seleccionadas bajo una única solución que gestione y controle el flujo de ejecución entre los diferentes módulos.
- Diseñar una arquitectura modular y escalable que permita futuras ampliaciones y facilite el mantenimiento del sistema.
- Implementar una interfaz gráfica amigable que simplifique el uso de la herramienta, incluso para usuarios con conocimientos técnicos limitados.

- Incorporar un sistema de gestión de objetivos basado en proyectos, con el objetivo de mejorar la organización y el seguimiento de los análisis realizados.
- Integrar un sistema de inteligencia artificial que proporcione asistencia contextual al usuario y sugerencias sobre acciones posteriores a los resultados obtenidos.
- Generar informes técnicos de forma automática a partir de los resultados del reconocimiento, presentando la información de manera clara y visual.
- Permitir la ejecución de la herramienta mediante consola, ampliando su adaptabilidad a distintos perfiles de usuario.
- Ofrecer distintas opciones de configuración para que la herramienta pueda ajustarse a distintos escenarios de análisis y niveles de profundidad.

Capítulo 3

Estado del Arte

Contenidos

3.1. Evolución de las auditorías de seguridad 9

3.2. Herramientas de reconocimiento automatizado 10

3.2.1. ProjectDiscovery Cloud 11

3.2.2. Intruder.io 12

3.2.3. Detectify 14

3.3. Comparativa de las soluciones analizadas 15

3.1. Evolución de las auditorías de seguridad

Las auditorías de seguridad informática surgieron como una respuesta directa al crecimiento exponencial de las redes informáticas y a la necesidad de proteger la información en entornos corporativos y gubernamentales. A medida que las tecnologías digitales comenzaron a formar parte de infraestructuras críticas y operaciones empresariales a gran escala, también aumentaron los incidentes relacionados con accesos no autorizados, robo de información, interrupciones de servicio y ataques maliciosos.

El concepto de auditoría de seguridad se consolidó a finales de los años 70 y principios de los 80, coincidiendo con la adopción masiva de sistemas informáticos interconectados. Durante este periodo, se desarrollaron algunos de los primeros estudios sistemáticos sobre cómo evaluar la seguridad de sistemas informáticos ante accesos no autorizados o comportamientos anómalos. Un ejemplo temprano es el informe *Computer Security Technology Planning Study* elaborado por James P. Anderson en 1972 [2, 3], considerado uno de los documentos fundacionales en la definición de objetivos y estrategias para el análisis técnico de la seguridad.

Durante los años 90, con la expansión global de Internet, surgieron las primeras metodologías estructuradas de auditoría como respuesta a nuevas amenazas, especialmente enfocadas en proteger servidores web, sistemas de correo y bases de datos. Herramientas como `SATAN` (Security Administrator Tool for Analyzing Networks), lanzada en 1995, marcaron un hito como una de las primeras aplicaciones orientadas a la detección de vulnerabilidades de red de forma semiautomática [4].

En paralelo, comenzaron a popularizarse los conceptos de "penetration testing" (pruebas de penetración) y "ethical hacking", que planteaban escenarios controlados de ataque con el fin de identificar debilidades antes de que pudieran ser explotadas por actores maliciosos. Con el tiempo, este enfoque evolucionó en metodologías más completas, como OSSTMM (Open Source Security Testing Methodology Manual) [5] o OWASP Testing Guide [6], que establecieron marcos de referencia para evaluar sistemas desde

una perspectiva técnica y organizada.

Actualmente, las auditorías de seguridad constituyen una práctica esencial dentro de la ciberseguridad defensiva y ofensiva. Su objetivo no se limita únicamente a identificar vulnerabilidades, sino también a priorizarlas, documentarlas y proponer soluciones antes de que puedan ser explotadas en un entorno real. La creciente complejidad de los entornos IT y la aparición de nuevos vectores de ataque han motivado la evolución constante de estas auditorías hacia modelos más automatizados, escalables y adaptables a distintos perfiles de organización.

3.2. Herramientas de reconocimiento automatizado

Con la creciente demanda de eficiencia en los procesos de auditoría de seguridad, especialmente en sus fases iniciales, han surgido en los últimos años múltiples plataformas orientadas a la automatización del reconocimiento y la detección de vulnerabilidades. Estas herramientas buscan reducir la carga operativa del analista, minimizar errores humanos y mejorar la cobertura frente a configuraciones y tecnologías cada vez más diversas.

Una de las propuestas más destacadas en este ámbito es ProjectDiscovery Cloud [7], una plataforma construida sobre herramientas open source ampliamente utilizadas en la comunidad de ciberseguridad, como `Nuclei`, `Httpx`, `Subfinder` o `Dnsx`. Su enfoque se basa en ofrecer un entorno colaborativo, escalable y continuamente actualizado para la detección de vulnerabilidades en activos expuestos a Internet. Aunque su núcleo es técnico, la plataforma proporciona una interfaz web amigable para la gestión de proyectos, permitiendo a los equipos de seguridad integrar fácilmente estos escaneos en flujos de trabajo automatizados.

Otra alternativa relevante es Intruder.io [8], un servicio orientado a empresas que buscan externalizar parte de su vigilancia de ciberseguridad. Intruder.io se centra en

la gestión de vulnerabilidades y la supervisión de la superficie de ataque, integrándose con entornos cloud como AWS o Azure. Su propuesta incluye escaneos automáticos, priorización de riesgos y reportes con recomendaciones técnicas, sin requerir una intervención manual intensiva, aunque con una menor flexibilidad técnica en comparación con herramientas de línea de comandos.

Por su parte, Detectify [9] ofrece un enfoque complementario basado en la inteligencia colectiva, donde una comunidad de hackers éticos colabora aportando módulos de detección de vulnerabilidades, incluyendo incluso algunos 0-days [10]. Esta plataforma permite escaneos web completos, incluyendo aplicaciones protegidas por autenticación, y destaca por su integración con herramientas de desarrollo y gestión como GitHub, Jira o Slack. Además, incorpora técnicas de fingerprinting avanzadas para adaptar sus pruebas al stack tecnológico específico de cada objetivo.

3.2.1. ProjectDiscovery Cloud

ProjectDiscovery Cloud es una plataforma de seguridad ofensiva que se construye sobre herramientas de código abierto ampliamente adoptadas por la comunidad de pentesting, como `Nuclei`, `Httpx`, `Subfinder`, `Naabu` o `Dnsx`. Su objetivo principal es facilitar la automatización del reconocimiento y la identificación de vulnerabilidades en activos expuestos, ofreciendo una experiencia escalable, colaborativa y fácil de integrar en flujos de trabajo modernos.

Entre sus principales características destacan:

- **Escaneo de puertos y servicios**: utiliza `Naabu` para detectar puertos abiertos en los objetivos definidos, permitiendo descubrir servicios accesibles desde Internet.
- **Enumeración de subdominios**: se apoya en `Subfinder` para identificar subdominios del dominio objetivo, lo cual permite ampliar la superficie de ataque.
- **Escaneo de vulnerabilidades web**: emplea `Nuclei` como motor principal para

ejecutar pruebas basadas en plantillas YAML contra los activos detectados. Estas plantillas permiten buscar fallos de seguridad en servicios HTTP, encabezados, tecnologías, versiones o patrones de exposición comunes.

- **Detección de tecnologías**: con herramientas como `Httpx`, la plataforma identifica frameworks, CMS o servidores web en uso.
- **Gestión de proyectos**: permite organizar los objetivos dentro de espacios de trabajo, visualizar resultados agrupados y priorizar vulnerabilidades según su criticidad.
- **Interfaz web y CLI**: proporciona tanto una interfaz gráfica intuitiva como una línea de comandos para ejecutar las herramientas por separado o integrarlas en scripts.

Sin embargo, la plataforma tiene ciertas limitaciones. Por ejemplo, no incluye reconocimiento detallado de servicios específicos como FTP o SSH, ni ofrece funciones de OSINT orientadas a la detección de correos filtrados o información expuesta de usuarios. Tampoco integra asistentes inteligentes para analizar los resultados, ni proporciona informes de forma nativa.

En cuanto a la disponibilidad, ProjectDiscovery Cloud ofrece una modalidad gratuita con funcionalidades limitadas, ideal para usuarios técnicos que ya están familiarizados con sus herramientas open source. Los planes comerciales amplían capacidades como la colaboración multiusuario o el acceso a plantillas explusivas.

3.2.2. Intruder.io

Intruder.io es una plataforma de escaneo de vulnerabilidades enfocada en entornos empresariales, cuyo objetivo principal es simplificar la supervisión de la superficie de ataque y automatizar la detección de debilidades técnicas. Su propuesta se centra

en ofrecer una experiencia gestionada, accesible a equipos de TI y seguridad que no necesariamente cuentan con perfiles técnicos especializados.

Las características principales de Intruder.io incluyen:

- **Escaneo de puertos y servicios**: permite identificar puertos abiertos y servicios disponibles en los activos definidos, tanto en entornos externos como internos. Esta capacidad es parte de su sistema de supervisión continua.
- **Enumeración de subdominios**: incluye detección automática de subdominios asociados a dominios registrados, para ampliar la visibilidad sobre activos inadvertidos.
- **Escaneo de vulnerabilidades web**: utiliza una base de pruebas automatizadas para detectar vulnerabilidades comunes en aplicaciones web, como inyecciones, XSS o configuraciones inseguras.
- **Gestión de activos y proyectos**: organiza los resultados por organización y objetivos, permitiendo la priorización basada en el riesgo, e integración con herramientas como AWS o Azure para escanear nuevos servicios desplegados automáticamente.
- **Interfaz web**: proporciona una interfaz gráfica sencilla, centrada en accesibilidad y claridad de resultados.

A pesar de las características previamente mencionadas, Intruder.io presenta varias limitaciones comparado con la solución propuesta en este trabajo. No permite ejecución mediante línea de comandos, lo cual restringe su integración en flujos automatizados personalizados. Tampoco realiza reconocimiento específico sobre servicios como FTP o SSH, ni incluye análisis de correos expuestos o técnicas de OSINT. Además, no ofrece análisis mediante inteligencia artificial para la interpretación de los resultados obtenidos.

Su modelo de uso se basa principalmente en suscripción comercial. No dispone de una versión gratuita para auditorías técnicas avanzadas, lo que puede suponer una barrera de entrada para usuarios individuales.

3.2.3. Detectify

Detectify es una plataforma de escaneo de seguridad web orientada a organizaciones que necesitan identificar y corregir vulnerabilidades en aplicaciones expuestas a Internet. Su enfoque combina el uso de pruebas automatizadas con inteligencia de amenazas aportada por una comunidad de más de 400 hackers éticos, quienes contribuyen con módulos de detección actualizados, incluyendo vulnerabilidades recientes e incluso 0-days.

Entre sus principales funcionalidades destacan:

- **Escaneo de puertos y servicios**: realiza detección básica de servicios expuestos, aunque centrado principalmente en protocolos web.
- **Enumeración de subdominios**: detecta subdominios relacionados con el dominio objetivo, y los incluye como parte del análisis continuo de la superficie de ataque.
- **Reconocimiento DNS**: ofrece visibilidad sobre registros DNS, lo que permite detectar configuraciones erróneas y posibles riesgos de seguridad.
- **Detección de tecnologías y CMS**: realiza fingerprinting de tecnologías, frameworks y gestores de contenido como WordPress, Joomla o Drupal, adaptando las pruebas de seguridad a cada stack detectado.
- **Escaneo de vulnerabilidades web**: emplea pruebas dinámicas (DAST) para identificar fallos como XSS, inyecciones SQL, exposición de archivos sensibles y configuraciones inseguras.
- **IA para análisis y priorización**: recientemente ha incorporado una herramienta basada en inteligencia artificial, *Alfred*, que ayuda a priorizar vulnerabilidades y

generar pruebas automatizadas.

- **Gestión de activos y generación de informes**: permite agrupar objetivos, gestionar su historial de escaneos y generar informes detallados con recomendaciones técnicas. Estos informes son exportables y compatibles con herramientas como Jira, Slack o GitHub.

Detectify ofrece una experiencia potente y pulida en el ámbito web, especialmente adecuada para equipos de desarrollo que integran la seguridad dentro del ciclo de vida del software (DevSecOps). No obstante, presenta ciertas limitaciones cuando se compara con herramientas orientadas a auditorías ofensivas más amplias. No dispone de ejecución mediante línea de comandos, ni permite escanear servicios que no sean web, como FTP o SSH.

Otro aspecto relevante es que Detectify no ofrece una capa gratuita, lo que lo posiciona claramente como una solución orientada a clientes corporativos con necesidades específicas y presupuesto disponible.

3.3. Comparativa de las soluciones analizadas

La Tabla 3.1 resume las capacidades clave de cada herramienta comparada, destacando tanto las funcionalidades comunes como las características diferenciales que aporta la solución desarrollada.

Característica	Propuesta	ProjectDiscovery Cloud	Intruder.io	Detectify
Escaneo de puertos y servicios	✓	✓	✓	✓
Enumeración de subdominios	✓	✓	✓	✓
Reconocimiento DNS	✓	✗	✗	✓
Escaneo específico por CMS	✓	✗	✗	✓
Escaneo de vulnerabilidades web	✓	✓	✓	✓
Reconocimiento específico de servicios	✓	✗	✗	✗
OSINT sobre direcciones de correo	✓	✗	✗	✗
Gestión de proyectos/objetivos	✓	✓	✓	✓
Generación de reportes versionados	✓	✗	✓	✓
IA integrada para asistencia y análisis	✓	✗	✗	✓
Interfaz web	✓	✓	✓	✓
Ejecución por CLI	✓	✓	✗	✗
Servicio gratuito	✓	✓	✗	✗

Tabla 3.1: Comparativa entre la herramienta desarrollada y soluciones similares.

Tras revisar las principales plataformas orientadas al reconocimiento automatizado en auditorías de seguridad, se observa que, si bien ofrecen soluciones potentes en distintos aspectos, presentan limitaciones significativas en cuanto a personalización, cobertura de vectores no web, o interacción con los resultados obtenidos. Estas carencias evidencian la necesidad de desarrollar herramientas más flexibles y adaptadas a un análisis técnico más profundo, como la que se propone en este trabajo.

Capítulo 4

Metodología

Contenidos

4.1. Estudio de la fase de reconocimiento 18

4.1.1. Metodologías de referencia 18

4.1.2. Enfoque adoptado en este trabajo 19

4.2. Análisis y elección de herramientas 20

4.2.1. Criterios de selección 20

4.2.2. Comparativa de herramientas consideradas 22

Tal y como se ha mencionado en capítulos anteriores, la fase de reconocimiento constituye un componente fundamental dentro de cualquier auditoría de seguridad. Su correcta ejecución permite identificar activos expuestos, tecnologías empleadas y posibles vectores de ataque. Por este motivo, resulta esencial contar con una metodología adecuada que permita abordar esta fase de forma eficiente, estructurada y efectiva.

4.1. Estudio de la fase de reconocimiento

La fase de reconocimiento en una auditoría de seguridad consiste en el conjunto de técnicas empleadas para recopilar, de forma activa o pasiva, información relevante sobre un objetivo. Dicha información puede incluir aspectos como servicios expuestos, dominios relacionados, tecnologías utilizadas, direcciones de correo filtradas o configuraciones vulnerables. Esta etapa inicial es crucial, ya que establece las bases para el resto del proceso de auditoría: a partir de estos datos se pueden identificar posibles vectores de ataque, evaluar superficies expuestas y priorizar futuras acciones ofensivas o defensivas.

Al tratarse de una fase con un alto grado de repetitividad y lógica condicional (por ejemplo, "si el puerto 21 está abierto, normalmente asociado al servicio `FTP`, comprobar acceso anónimo"), es especialmente adecuada para ser automatizada. Automatizarla no solo ahorra tiempo y esfuerzo humano, sino que mejora la consistencia y trazabilidad de los resultados obtenidos, al aplicar siempre el mismo flujo metodológico ante situaciones similares.

4.1.1. Metodologías de referencia

Para establecer un marco sólido sobre el cual diseñar el flujo de reconocimiento implementado, se han estudiado tres metodologías ampliamente aceptadas en el ámbito de la ciberseguridad:

- **OWASP Web Security Testing Guide (WSTG)** [11]: guía enfocada a la seguridad de aplicaciones web. Incluye en sus primeras fases una serie de pruebas relacionadas con la recolección de información (como descubrimiento de subdominios, fingerprinting de tecnologías, análisis de DNS o WHOIS). Su orientación a entornos web y enfoque sistemático la convierten en una referencia especialmente útil para este proyecto.

- **MITRE ATTACK Framework** [12]: base de conocimiento que documenta técnicas utilizadas por profesionales en el mundo real. La táctica de *Reconnaissance* incluye técnicas como escaneo activo, recolección de DNS, WHOIS lookup, entre otras. Su grado de detalle la convierten en una fuente ideal para este proyecto.

- **OSSTMM (Open Source Security Testing Methodology Manual)** [13]: metodología de auditoría que organiza el análisis por canales de interacción y define la enumeración como una parte esencial del proceso de reconocimiento. Aunque es más generalista y menos enfocada al entorno web, proporciona una base de conocimientos sólida.

4.1.2. Enfoque adoptado en este trabajo

Las tres metodologías han sido consideradas como referencia durante el diseño de la herramienta, y en cierto modo, se han aplicado facetas de todas ellas. No obstante, el enfoque metodológico seguido no se ha adherido estrictamente a ninguna de ellas de forma literal. En su lugar, se ha optado por una aplicación flexible, combinando lo más relevante de cada marco con criterios prácticos derivados de la experiencia técnica y del objetivo del proyecto.

Concretamente, el diseño del flujo de reconocimiento se apoya principalmente en las directrices del marco OWASP, dada su orientación clara a entornos web, y en la estructura del marco MITRE ATTACK, por su nivel de detalle y organización táctica. La herramienta incorpora fases descritas en ambos marcos, como el fingerprinting de tecnologías, el escaneo

de vulnerabilidades web o la recopilación de información DNS y WHOIS.

Sin embargo, también se han añadido tareas no descritas explícitamente en dichos marcos, como el escaneo de puertos y servicios o el análisis de servicios específicos, por considerarse elementos fundamentales en un reconocimiento técnico completo. Del mismo modo, algunas técnicas presentes en ATTACK o OSSTMM han sido descartadas por no ajustarse al alcance funcional de esta herramienta.

Las fases implementadas se documentan con mayor detalle en los apartados siguientes, donde se describen las herramientas y tecnologías utilizadas en cada etapa, así como el flujo metodológico exacto que sigue la herramienta.

4.2. Análisis y elección de herramientas

La elección de herramientas adecuadas resulta clave para garantizar la eficacia, eficiencia y fiabilidad. En el desarrollo de este proyecto, se han analizado diversas alternativas tecnológicas disponibles para cada una de las tareas que conforman la fase de reconocimiento, valorando sus prestaciones, grado de actualización, facilidad de integración, rendimiento y adecuación al flujo metodológico propuesto.

Este apartado presenta, en primer lugar, los criterios que han guiado la selección de dichas herramientas. Posteriormente, se comparan distintas opciones consideradas para cada funcionalidad, justificando la decisión final adoptada en cada caso.

4.2.1. Criterios de selección

Para la elección de la herramienta más adecuada en cada una de las fases del reconocimiento, se han definido una serie de criterios con el fin de asegurar su alineación con los objetivos de la solución desarrollada. Estos criterios se han priorizado en función de su relevancia dentro del contexto del proyecto, siendo los siguientes, ordenados de mayor

a menor importancia:

- **Grado de reconocimiento**: Se valora el uso extendido y el reconocimiento de la herramienta en entornos profesionales.
- **Facilidad de integración**: Se seleccionan herramientas que puedan integrarse de manera sencilla en el flujo de ejecución de la solución, preferiblemente aquellas que ofrezcan soporte en línea de comandos, salida en formatos tratables (JSON, CSV) o APIs.
- **Rendimiento**: Se evalúa la eficiencia en el uso de recursos y la velocidad de ejecución.
- **Actualización activa**: Se priorizan herramientas con desarrollo activo y mantenimiento continuo, así como con una comunidad de usuarios que contribuya regularmente a su evolución.
- **Flexibilidad**: Se prefieren herramientas que permitan ajustes de configuración, modo de ejecución, profundidad de análisis y adaptación a distintos escenarios de uso.
- **Documentación**: Se considera importante la existencia de una documentación clara, actualizada y accesible, que facilite tanto su uso como su integración y mantenimiento.

A partir de estos criterios, se ha llevado a cabo un análisis exhaustivo de las distintas alternativas disponibles para cada etapa del reconocimiento. Las decisiones adoptadas, así como las herramientas finalmente seleccionadas, se presentan y justifican en los apartados siguientes.

4.2.2. Comparativa de herramientas consideradas

Una vez definidos los criterios de selección, en este apartado se presenta la toma de decisiones llevada a cabo para la elección de cada una de las herramientas de las distintas fases.

Escaneo de puertos y servicios

Para la etapa de escaneo de puertos y servicios se ha seleccionado **Nmap** [14], una de las herramientas más consolidadas y ampliamente utilizadas en el ámbito de la ciberseguridad. Su elección fue clara debido a su reconocimiento como estándar para el descubrimiento de puertos abiertos, detección de servicios y recopilación de información sobre los sistemas analizados.

Nmap destaca por su robustez, su comunidad activa de usuarios, la disponibilidad de documentación extensa y su versatilidad para adaptarse a distintos niveles de profundidad en el análisis. Además, permite realizar detección de versiones y ejecución de scripts específicos mediante su motor NSE (Nmap Scripting Engine), funcionalidades que otras alternativas no alcanzan al mismo nivel.

Durante el proceso de selección se valoraron también otras herramientas como **Masscan** [15], reconocida por su velocidad de escaneo en redes de gran tamaño, pero que no ofrece detección de servicios ni análisis detallado. Asimismo, se consideró **RustScan** [16], una herramienta moderna que destaca por su rapidez y eficiencia, pero que no cuenta con la misma consolidación ni comunidad que Nmap.

La Tabla 4.1 resume la comparativa entre estas tres herramientas aplicando los criterios definidos anteriormente.

Herramienta	Reconocimiento	Integración	Rendimiento	Actualización	Flexibilidad	Documentación
Nmap	★★★	★★★	★★☆	★★★	★★★	★★★
Masscan	★★☆	★★☆	★★★	★★☆	★☆☆	★☆☆
RustScan	★★☆	★★★	★★★	★★★	★★☆	★★★

Tabla 4.1: Comparativa de herramientas para escaneo de puertos y servicios.

Teniendo en cuenta esto, **Nmap** ha sido la opción seleccionada para cubrir esta fase, por ser la herramienta más completa, consolidada y adecuada para los objetivos del proyecto.

Reconocimiento DNS

La etapa de reconocimiento DNS tiene como objetivo recopilar la mayor cantidad de información posible relacionada con la infraestructura DNS del objetivo. Para ello se han utilizado tres herramientas, cada una especializada en una funcionalidad específica:

- **DNSdumpster** [17]: empleada para consultar y visualizar registros DNS públicos del dominio, incluyendo registros `MX` (servidores de correo), `NS` (servidores de nombres) y `TXT` (configuraciones SPF, DKIM, etc.).
- **MXToolbox** [18]: utilizada específicamente para la consulta del registro `DMARC`, el cual proporciona mecanismos de protección frente a ataques de suplantación de identidad mediante correo electrónico (*email spoofing* [19]).
- **API Ninja (WHOIS)** [20]: empleada para realizar consultas WHOIS y obtener información sobre la propiedad del dominio, la fecha de creación y expiración, así como otros datos administrativos relevantes.

Durante el proceso de selección de estas herramientas, se consideraron varias alternativas que ofrecían funcionalidades similares.

En primer lugar, se necesitaba una herramienta que permitiera consultar registros DNS públicos. En este caso se optó por **DNSdumpster**, que destaca por su facilidad de uso e integración gracias a la amplia capa gratuita que ofrece su API. Aunque existen otras herramientas como **dnsrecon** o **dnsenum**, se descartaron por las siguientes razones:

- **dnsrecon** [21]: ofrece buenos resultados, pero su integración en la herramienta resultaba menos práctica, ya que no genera salidas en formatos estructurados como JSON.
- **dnsenum** [22]: no proporciona tanta información como DNSdumpster y presenta un mantenimiento limitado, con escasa actividad reciente en su desarrollo.
- **Amass** [23]: una herramienta potente y moderna, pero con una integración algo más compleja.

La Tabla 4.2 resume la comparativa entre estas herramientas siguiendo los criterios definidos anteriormente.

Herramienta	Reconocimiento	Integración	Rendimiento	Actualización	Flexibilidad	Documentación
DNSdumpster	★★☆	★★★	★★★	★★★	★★★	★★★
Dnsrecon	★★☆	★☆☆	★★☆	★★☆	★★☆	★★★
Dnsenum	★★☆	★☆☆	★★☆	★☆☆	★★☆	★★★
Amass	★★☆	★★☆	★★★	★★☆	★★★	★★★

Tabla 4.2: Comparativa de herramientas para reconocimiento de registros DNS.

La facilidad de integración, la amplia capa gratuita de su API y la calidad de la información obtenida llevaron a seleccionar **DNSdumpster** como la herramienta más adecuada para cumplir esta función.

Otra parte fundamental dentro del reconocimiento DNS es la consulta del registro `DMARC`. El mantenimiento y la monitorización de este registro son aspectos clave para

garantizar la autenticidad del dominio y protegerlo frente a ataques de suplantación de identidad mediante correo electrónico.

Para esta tarea se optó por utilizar **MXToolbox** debido a su simplicidad de uso y a la disponibilidad de su funcionalidad DMARC a través de una API para realizar la consulta. Aunque existen otras plataformas como **EasyDMARC** [24], estas no ofrecen una API pública, lo que complica su integración en flujos automatizados como el propuesto en esta herramienta.

El número de herramientas con esta funcionalidad específica y con capacidad de integración es muy limitado, lo que llevó a seleccionar **MXToolbox** como la opción más adecuada.

Capítulo 5

Implementación y desarrollo

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Capítulo 6

Resultados

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Ambling web principal (https://ambling.es/) – Escaneo normal:

Ambling web principal (https://ambling.es/) – Escaneo exahustivo:

Ambling clientes (https://clientes.ambling.es/) – Escaneo normal:

Ambling clientes (https://clientes.ambling.es/) – Escaneo exahustivo:

Ambling caucces (https://caucces.ambling.es/) – Escaneo normal:

Ambling caucces (https://caucces.ambling.es/) – Escaneo exahustivo:

Capítulo 7

Conclusiones y trabajos futuros

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Anexos

Anexo A

Ejemplo de anexo

Contenidos

A.1. Sección de anexo 30

Si no se desea incluir anexos, sólo hay que borrar este capítulo.

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

A.1. Sección de anexo

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Bibliografía

[1] MITRE ATTACK. Reconnaissance, 2020. Fase de reconocimiento en auditorías de seguridad. URL: https://attack.mitre.org/tactics/TA0043/.

[2] James P. Anderson. Computer security technology planning study, volume 1. Technical report, U.S. Air Force Electronic Systems Division, 1972. Informe pionero sobre planificación y análisis de seguridad informática, volumen 1. URL: https://csrc.nist.gov/files/pubs/conference/1998/10/08/proceedings-of-the-21st-nissc-1998/final/docs/early-cs-papers/ande72a.pdf.

[3] James P. Anderson. Computer security technology planning study, volume 2. Technical report, U.S. Air Force Electronic Systems Division, 1972. Informe pionero sobre planificación y análisis de seguridad informática, volumen 2. URL: https://csrc.nist.rip/publications/history/ande72.pdf.

[4] Dan Farmer and Wietse Venema. Satan: Security administrator tool for analyzing networks, 1995. Herramienta pionera de escaneo de vulnerabilidades en redes UNIX. URL: http://www.porcupine.org/satan.

[5] ISECOM. Isecom - institute for security and open methodologies. Sitio web oficial de ISECOM. URL: https://www.isecom.org.

[6] OWASP Foundation. Open web application security project (owasp), 2001. Sitio web oficial de OWASP. URL: https://owasp.org.

[7] ProjectDiscovery. Projectdiscovery cloud platform, 2024. Plataforma de escaneo automático basada en herramientas open source. URL: https://cloud.projectdiscovery.io/.

[8] Intruder Systems Ltd. Intruder.io - automated vulnerability scanner, 2024. Servicio de escaneo de vulnerabilidades orientado a empresas. URL: https://intruder.io/.

[9] Detectify AB. Detectify - web vulnerability scanner powered by ethical hackers, 2024. Plataforma de escaneo web basada en inteligencia colectiva. URL: https://detectify.com/.

[10] INCIBE. ¿qué es una vulnerabilidad zero day?, 2020. Publicación de INCIBE sobre vulnerabilidades de día cero. URL: https://www.incibe.es/ciudadania/blog/que-es-una-vulnerabilidad-zero-day.

[11] OWASP Foundation. *OWASP Web Security Testing Guide v4.2*, 2020. Metodología en el marco de OWASP. URL: https://owasp.org/www-project-web-security-testing-guide/v42/.

[12] MITRE Corporation. *MITRE ATTACK*, 2015. Metodología en el marco de MITRE ATTACK. URL: https://attack.mitre.org/.

[13] Pete Herzog. *OSSTMM – Open Source Security Testing Methodology Manual*, 2001. Metodología en el marco de OSSTMM. URL: https://www.isecom.org/OSSTMM.3.pdf.

[14] Nmap Project. Nmap - network mapper, 1997. Sitio web oficial de Nmap, herramienta de escaneo de puertos y servicios. URL: https://nmap.org.

[15] Robert Graham. Masscan: Mass ip port scanner. Repositorio oficial en GitHub del escáner de puertos Masscan. URL: https://github.com/robertdavidgraham/masscan.

[16] Bee-San. Rustscan: The modern port scanner. Repositorio oficial en GitHub del escáner de puertos RustScan. URL: https://github.com/bee-san/RustScan.

[17] HackerTarget.com. Dnsdumpster - online dns reconnaissance tool. Herramienta para visualización de registros DNS. URL: https://dnsdumpster.com/.

[18] Inc. MXToolbox. Mxtoolbox. Herramienta para análisis de registros DNS. URL: https://mxtoolbox.com/.

[19] Wikipedia contributors. Email spoofing. Definición del término "Email spoofing". URL: https://es.wikipedia.org/wiki/Email_spoofing.

[20] API Ninjas. Whois api - api ninjas. API REST para realizar consultas WHOIS sobre nombres de dominio. URL: https://www.api-ninjas.com/api/whois.

[21] Carlos Perez. dnsrecon - dns enumeration script. Script para enumeración y análisis de registros DNS. URL: https://github.com/darkoperator/dnsrecon.

[22] Filip Waeytens. dnsenum - multithreaded perl script to enumerate dns information. Script para descubrimiento de información DNS. URL: https://github.com/fwaeytens/dnsenum.

[23] OWASP Foundation. Amass - in-depth dns enumeration and attack surface mapping. Herramienta para mapeo de superficie de ataque. URL: https://github.com/owasp-amass/amass.

[24] EasyDMARC. Easydmarc – your dmarc journey made simple. Plataforma de validación de registro DMARC. URL: https://easydmarc.com/.